Tema 4.
Identificación, Autenticación y Autorización (II)

Dr. Rafael Martínez Gasca
Grupo de Investigación **Quivir**,
Tecnologías Inteligentes y de Seguridad de los Sistemas de Información
Departamento de Lenguajes y Sistemas Informáticos
Universidad de Sevilla





Indice

- Implementación de los requisitos de Identificación & Autenticación & Autorización
  - Identificación y Autenticación
    - Gestión de Identidades
    - Biometría, Passwords, Smartcard, Pattern Lock
    - Claves criptográficas. Certificados digitales. PKI
  - Autorización

- ¿Estamos identificados y autenticados y ahora qué pasa?



Implementación de Requisitos de Seguridad.
Autorización



Identificación

Autenticación

Autorización

Accountability



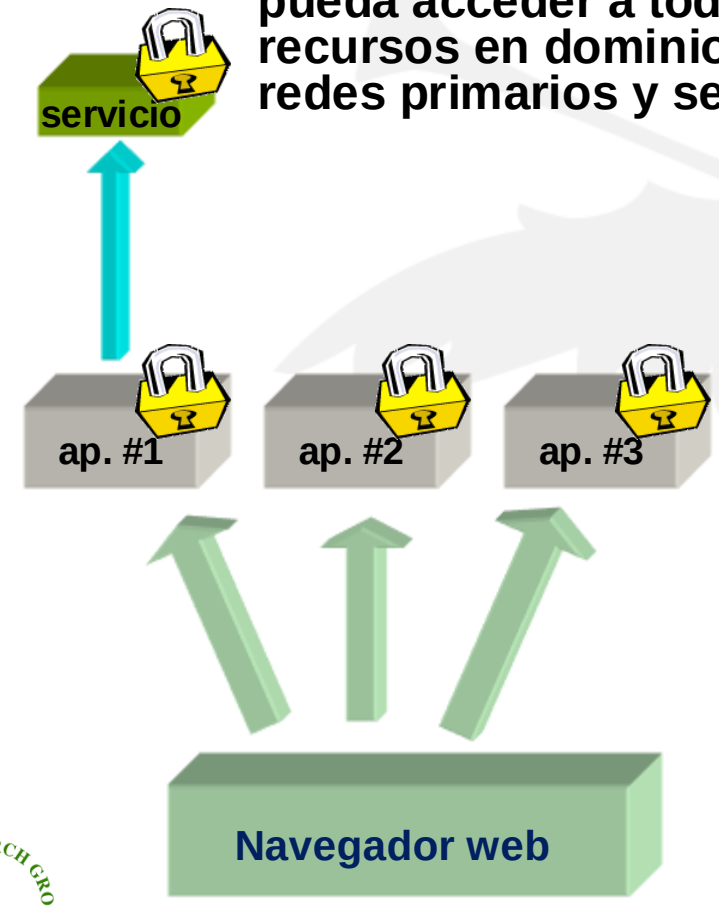
Autorización

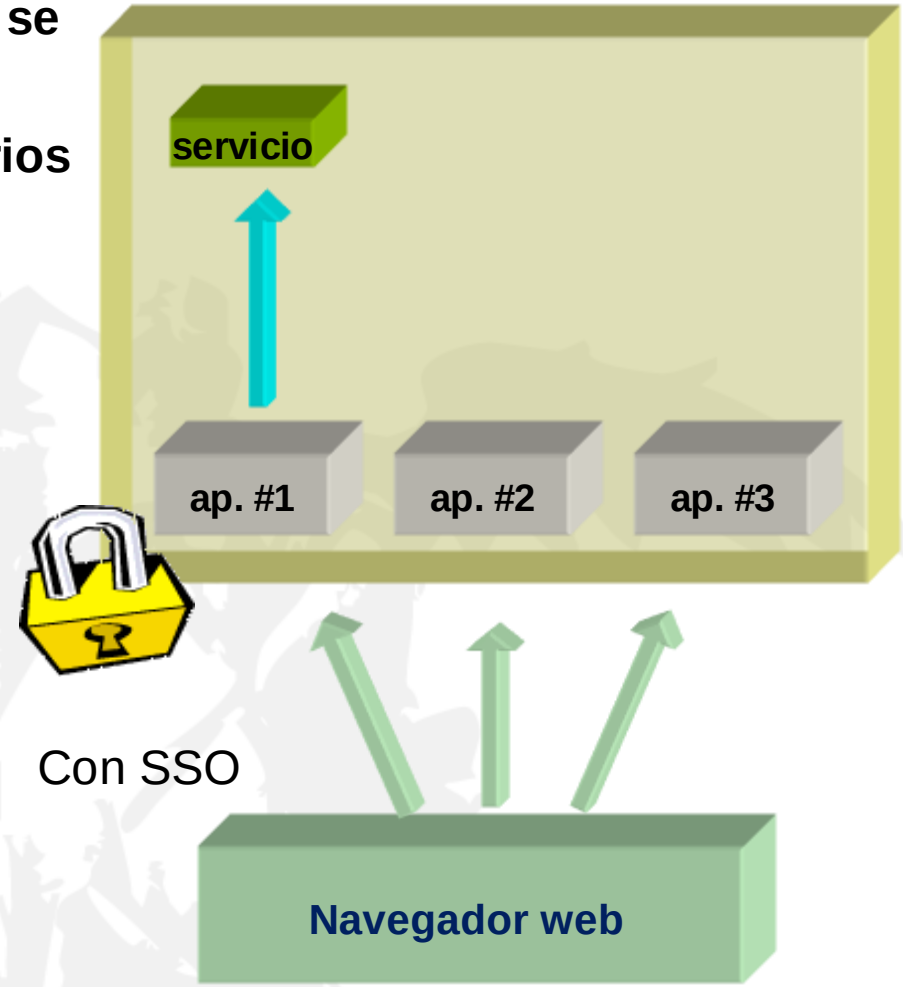
- Recordemos que era Autorización:
  - Acto de la determinación de los permisos de acceso de un sujeto **identificado y autenticado sobre un objeto**
  - **Implementación: Control de acceso:** mecanismo que en función de la identificación ya autenticada permite acceder a datos o recursos.
  - **Ejemplo LOPD** (RD 1720/2007) Artículo 91. ***Control de acceso***.
    1. Los usuarios tendrán acceso únicamente a aquellos recursos que precisen para el desarrollo de sus funciones.
    2. El responsable del fichero se encargará de que exista una relación actualizada de usuarios y perfiles de usuarios, y los accesos autorizados para cada uno de ellos.
    3. El responsable del fichero establecerá **mecanismos para evitar que un usuario pueda acceder a recursos con derechos distintos de los autorizados.**

- **Accountability: Ejemplo LOPD** (RD 1720/2007) para datos de nivel alto (salud) Artículo 103. ***Registro de accesos.***
  1. De cada intento de acceso se guardarán, como mínimo, la identificación del usuario, la fecha y hora en que se realizó, el fichero accedido, el tipo de acceso y si ha sido autorizado o denegado.
  2. En el caso de que el acceso haya sido autorizado, será preciso guardar la información que permita identificar el registro accedido.
  3. Los mecanismos que permiten el registro de accesos estarán bajo el control directo del responsable de seguridad competente sin que deban permitir la desactivación ni la manipulación de los mismos.
  4. El período mínimo de conservación de los datos registrados será de 2 años.
  5. El responsable de seguridad se encargará de **revisar al menos una vez al mes la información de control** registrada y elaborará un informe de las revisiones realizadas y los problemas detectados.

- Algunas cuestiones que deben abordarse al elaborar una **política de seguridad de control de acceso**:
  1. **¿Quién está autorizado a utilizar los recursos?**
  2. **¿Cuál es el uso adecuado de los recursos?**
  3. **¿Quién está autorizado a conceder el acceso?**
  4. **¿Quién puede tener privilegios de administración del sistema?**
  5. **¿Cuáles son los derechos del usuario y las responsabilidades?**
  6. **¿Cuáles son los derechos y responsabilidades del administrador del sistema frente a los de los usuarios?**
  7. **¿Qué hacemos con la información sensible? (por ej. privacidad)**

Single Sign On sistema que permite entregar las credenciales una vez y que se pueda acceder a todos los recursos en dominios de redes primarios y secundarios





Implementación de la Identificación y Autenticación.
Single Sign On

- Ventajas:
  - Centraliza la administración de usuarios/ contraseñas
  - Utilización de contraseñas fuertes y revisables (multifactor)
  - Facilidad de administración
- Desventajas:
  - Punto único de entrada.
  - Complejidad de implantar y operar
  - La unificación de todas las identidades conlleva que el servidor de identidad conocerá todas las webs que se visiten cada día
  - Si se comprometiera la seguridad del ordenador usuario o del servidor, toda la vida digital del usuario quedaría desprotegida

- Tecnologías
  - **Kerberos** es un método popular de externalizar la autenticación de los usuarios. Los usuarios se registran en el servidor Kerberos y reciben un "ticket", luego las aplicaciones-cliente lo presentan para obtener acceso
  - **Standard Oasis (SAML 2.0)** Es un SSO orientado a usuarios empresariales. Estándar abierto que define un esquema XML para el intercambio de datos de autenticación y autorización
  - **OpenID** es un SSO distribuido y descentralizado donde la identidad se compila en una url que cualquier aplicación o servidor puede verificar.
  - **Oath.** Es una API de autorización entre aplicaciones (Open Authentication) basada en tokens efímeros de autenticación. Agrupa a más de 30 fabricantes y sus especificaciones están basadas en diversos estándares

- Kerberos es el perro de tres cabezas que guarda la entrada a Hades. (Antiguo mito griego)



- Desarrollado por el MIT para centralizar la autenticación de usuarios.
- Kerberos mantiene una base de datos de claves secretas; cada entidad en la red —sea cliente o servidor— comparte una clave secreta conocida únicamente por él y Kerberos
- El conocimiento de esta clave sirve para probar la identidad de la entidad
- Para una comunicación entre dos entidades, Kerberos genera una clave de sesión, la cual pueden usar para asegurar sus comunicación
- Protocolo de autenticación muy difundido en entornos Unix

- Problemas:
  - Autenticación basada en lo bueno que es el password del cliente
  - Tiempo de vida asociado con el ticket de garantía
    - Si es demasido corto → repetición de solicitud de password
    - Si es demasiado largo → mayor oportunidad de replay
  - La amenaza es que el atacante pudiera robar el ticket y usarlo antes de que expire.

- SAML 2.0 es un protocolo basado en XML que:
  - usa **token de seguridad conteniendo aserciones** para pasar información del principal (generalmente **el usuario final**) entre una autoridad SAML (**proveedor de identidad**), y un consumidor SAML (**proveedor del servicio**).
  - Facilita la autenticación y autorización Web, incluyendo los escenarios de single sign-on (SSO).

1. El proveedor del servicio recibe la solicitud del cliente (principal), y la envia al Proveedor de Identidad para hacer la autenticación del cliente. ***El origen puede firmar la aserción SAML mediante un certificado x.509***

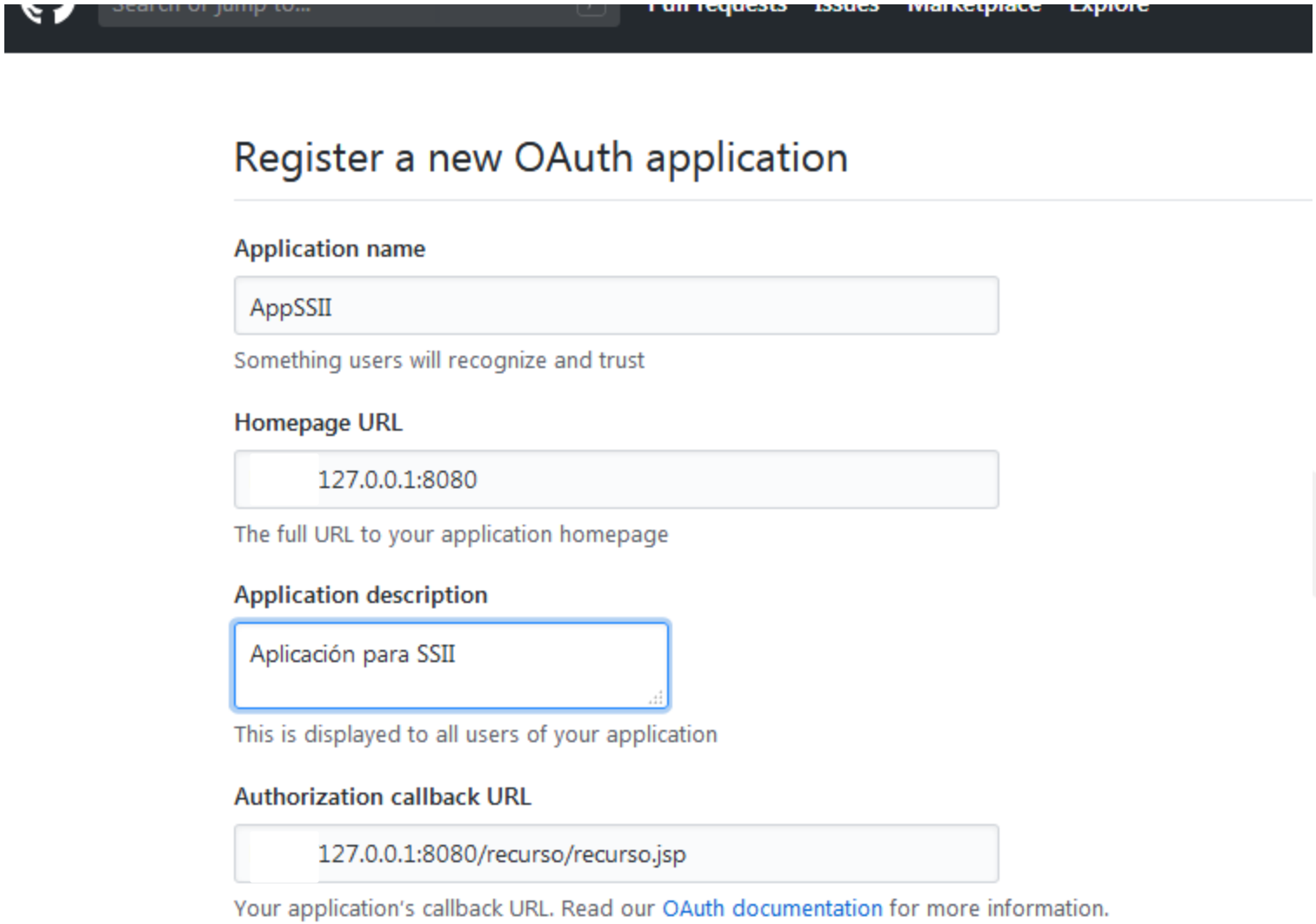
2. El Proveedor de identidad autentica al cliente y crea un token, y vuelve al Proveedor de Servicio

- SSO usando SAML
  - El token contiene la información de identificación. Esta información está 'firmada' por el servidor SSO.
  - Contiene información de seguridad para la validación sin tener que llamar al servidor SSO cada vez

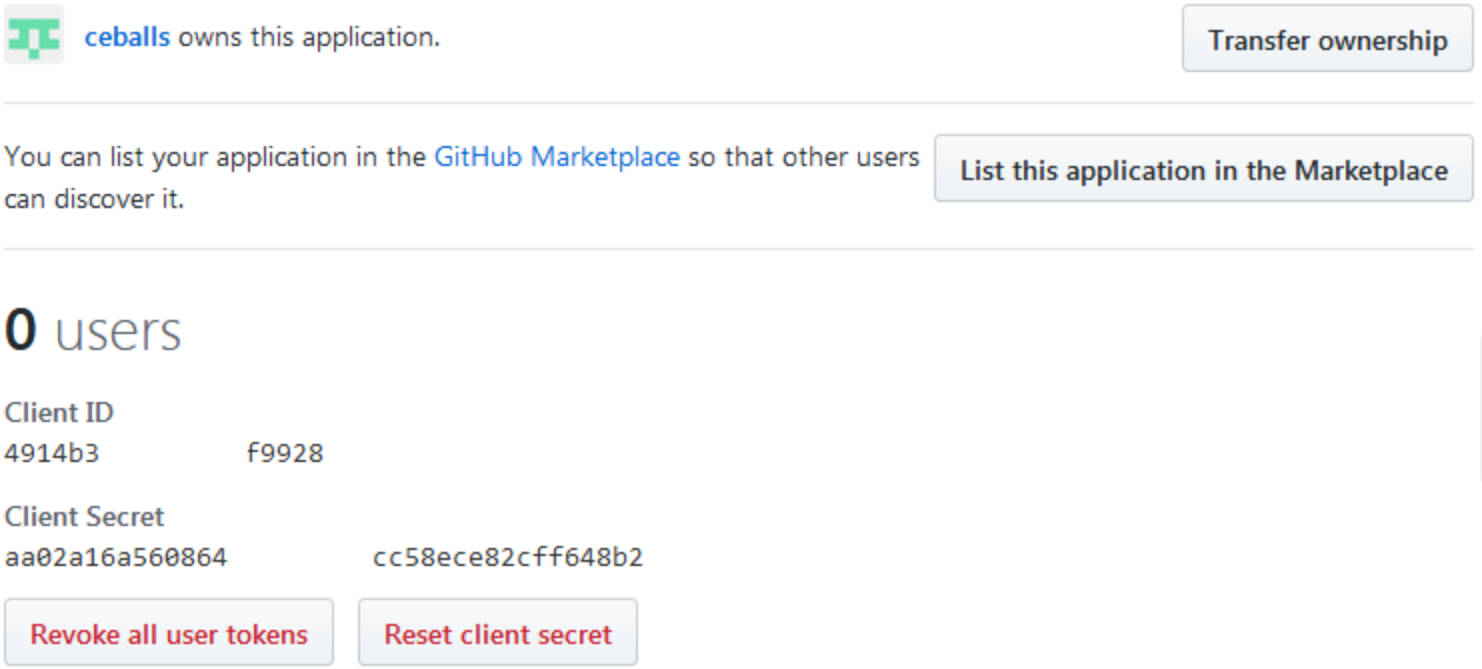
- OpenID es un estándar de identificación digital descentralizado, con el que un usuario puede identificarse en una página web a través de una URL
- La web externa usará la URL para verificar si el usuario es quien dice ser, y le dará acceso o no
- OpenID Connect utiliza OAuth 2.0

- OAuth 2 permite dar autorización a las aplicaciones basado en las cuentas de usuario de un servicio como Facebook, GitHub, Google...
- Delega la autenticación del usuario al servicio que aloja la cuenta del mismo y autoriza a las aplicaciones de terceros el acceso a dicha cuenta de usuario
- OAuth 2 proporciona flujos de autorización para aplicaciones web y de escritorio; y dispositivos móviles

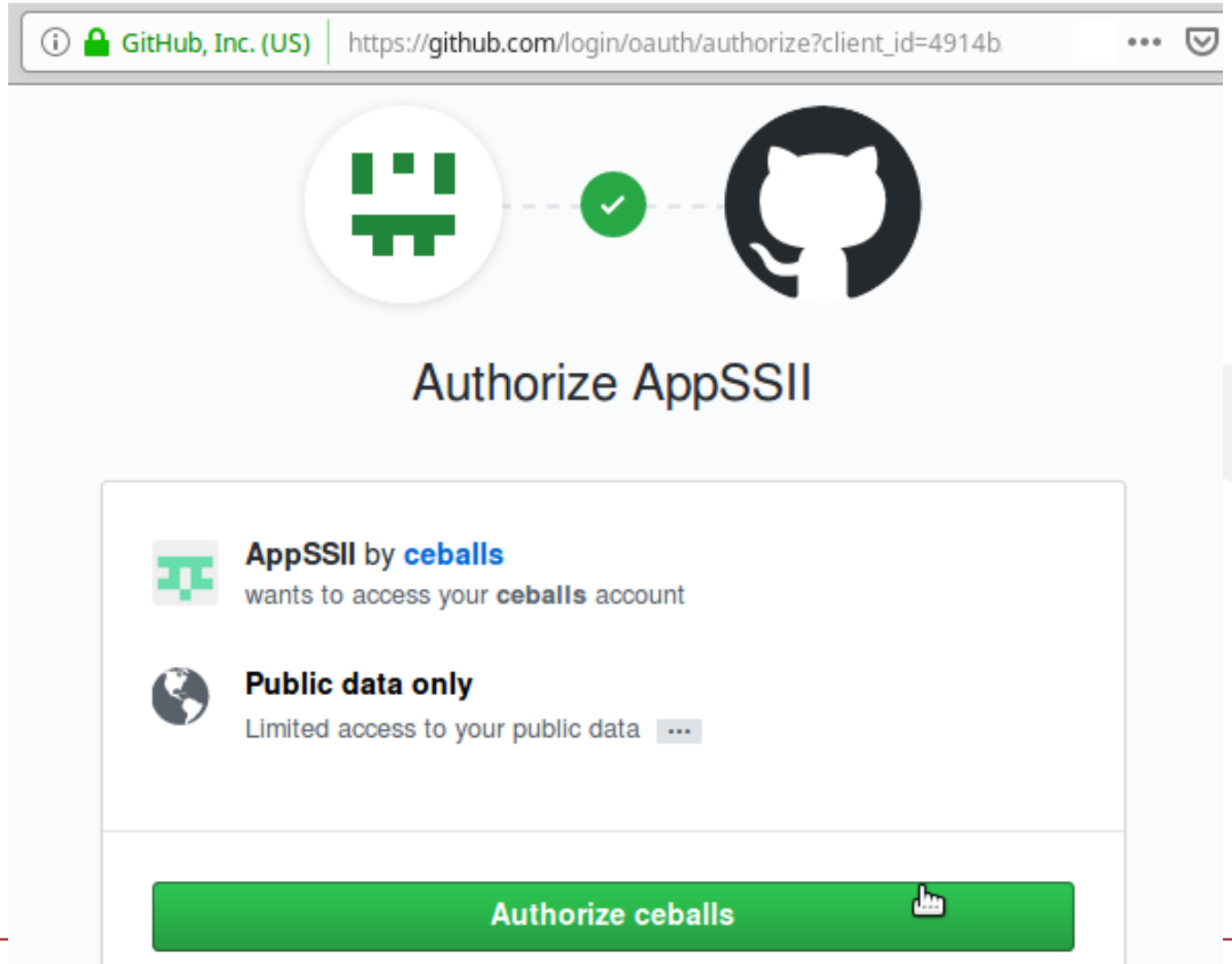
Implementación de la Autent. y Autoriz.
Oauth - GitHub



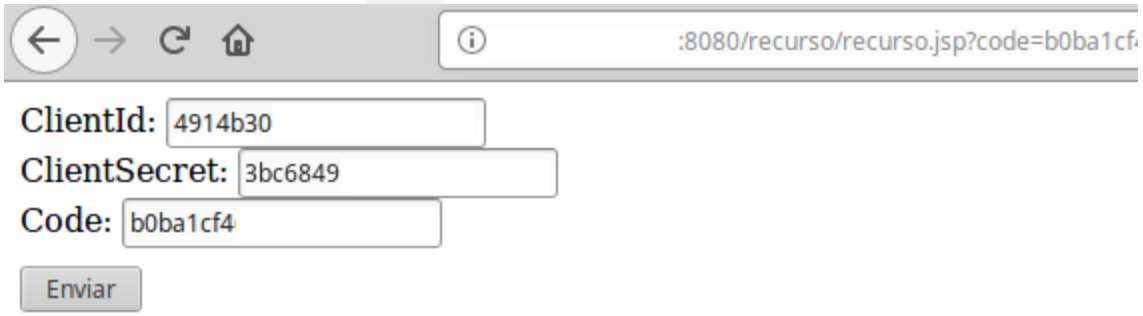
Implementación de la Autent. y Autoriz.
Oauth - GitHub

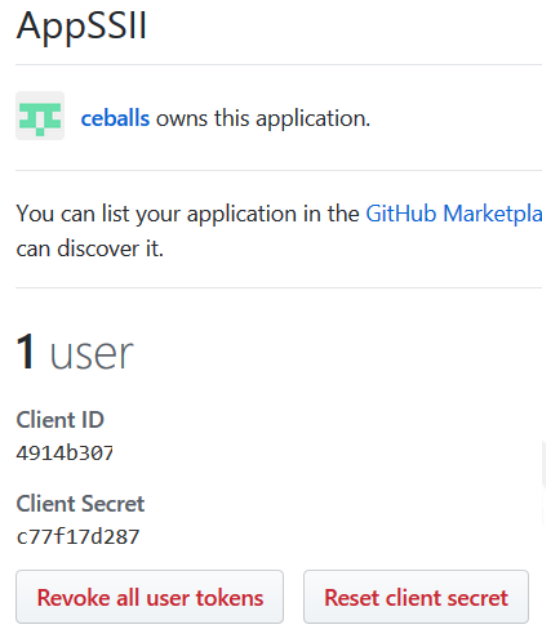


https://github.com/login/oauth/authorize?client_id=



- Petición token de acceso





- Se obtiene el token de acceso

access_token=6dbad3693dc9a52f….&scope=&token_type=bearer

Implementación de la Autent. y Autoriz.
Oauth - GitHub

